

=====

OWASP ZAP VULNERABILITY SUMMARY — Week 13 Scan

Target: <https://demo.owasp-juice.shop>

Scan Date: Wed 20 May 2026 | ZAP Version: 2.17.0

=====

TOTAL ALERTS: 7

High : 0

Medium : 2

Low : 3

Info : 2

VULNERABILITY LIST

1. [MEDIUM] Content Security Policy (CSP) Header Not Set

Count : 5 instances

CWE : CWE-693

WASC : 15

OWASP : A05:2021, A06:2017, A02:2025

Confidence: High (1), Medium (1)

Description: CSP header missing — allows XSS and data injection attacks.

2. [MEDIUM] Cross-Domain Misconfiguration

Count : 5 instances

CWE : CWE-264

WASC : 14

Description: Overly permissive CORS policy allows cross-domain resource access.

3. [LOW] Server Leaks Version Information via "Server" HTTP Response Header

Count : 3 instances

CWE : CWE-497

WASC : 13

Description: Server header discloses technology stack info (e.g., "Heroku").

4. [LOW] Strict-Transport-Security (HSTS) Header Not Set

Count : 5 instances

CWE : CWE-319

WASC : 15

Description: HSTS header missing — allows downgrade attacks and MITM.

5. [LOW] Timestamp Disclosure — Unix

Count : 5 instances

CWE : CWE-497

WASC : 13

Description: Unix timestamps exposed in responses — reveals internal timing info.

6. [INFO] Modern Web Application

Count : 5 instances

Description: Application uses modern single-page app framework (Angular/React).

7. [INFO] Re-examine Cache-control Directives

SVV

Count : 5 instances

CWE : CWE-525

WASC : 13

Description: Cache-control directives may expose sensitive content via browser cache.

SCAN STATISTICS

Total Endpoints Crawled : 135

2xx Responses : 95%

4xx Responses : 4%

ZAP Errors Logged : 1

ZAP Warnings Logged : 2

Slow Responses : 100%

=====